



Penetration Testing Report: Basic Pentesting (TryHackMe)

Target IP Address: 10.114.164.216

Date: June 19, 2026

Difficulty: Easy / Beginner

1. Executive Summary

A authorized security assessment was conducted against the target infrastructure at IP 10.114.164.216. The evaluation revealed significant security weaknesses, including an unauthenticated information leak via SMB network shares and an exposed development directory on the web server. By chaining these info-leaks, weak SSH credentials were brute-forced to gain low-privilege access. A secondary lateral movement pivot was executed by recovering and cracking an encrypted local SSH private key file, resulting in complete compromise of the target's primary user data.

2. Reconnaissance & Service Enumeration

An aggressive Nmap service scan was performed against the target to identify active listening network daemons:

Port	Protocol	State	Service	Version / Architecture Info
22	tcp	Open	SSH	OpenSSH (Ubuntu Linux)
80	tcp	Open	HTTP	Apache httpd Web Server
139	tcp	Open	NetBIOS	Samba NetBIOS-SSN
445	tcp	Open	SMB	Samba Share Service (Null Session Allowed)

Key Enumeration Findings:

- **Samba (Ports 139/445):** Allowed unauthenticated null sessions, enabling automated tooling like `enum4linux` to map internal structural variables and account identities.
- **Apache (Port 80):** Hosted a standard HTTP deployment hiding critical deployment files.

3. Vulnerability Analysis & Account Discovery

Track A: Web Directory Brute-Forcing

Using `gobuster`, directory enumeration was performed on the web root to locate unlinked assets:

Bash

```
gobuster dir -u http://10.114.164.216/ -w /usr/share/wordlists/dirb/common.txt
```

- **Discovery:** A hidden path `/development/` was identified.
- **Data Leak:** Inside this directory, two text logs (`dev.txt` and `j.txt`) were uncovered. The logs contained a raw chat conversation between developers initialized as "J" and "K", explicitly indicating that user "J" had configured an incredibly weak account password.

Track B: SMB User Enumeration

To map the true system names behind the initials "J" and "K", a comprehensive SMB enumeration scan was initiated:

Bash

```
enum4linux -A 10.114.164.216
```

- **Result:** The system's security boundaries leaked two active valid local Linux account usernames mapping perfectly to the web notes: `jan` and `kay`.

4. Exploitation (Initial Access)

With the confirmation that user `jan` possessed a weak security posture, an online dictionary attack was launched over the active SSH service (Port 22) using `Hydra` combined with the `rockyou.txt` wordlist matrix:

Bash

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt 10.114.164.216 ssh -V
```

- **Result:** Successful authentication match discovered.
- **Foothold Credentials:** `jan : [CRACKED_PASSWORD]`

Using these credentials, a low-privilege interactive terminal shell session was established via SSH.

5. Lateral Movement (Pivot to Kay)

Internal Enumeration

While logged in as **jan**, local file permissions were inspected to find internal vectors. Navigating to the neighboring user's profile (**/home/kay**) revealed an over-permissive configuration allowing other system users to traverse her active configurations.

- **Asset Located:** A hidden SSH private key file was exposed at **/home/kay/.ssh/id_rsa**.

Cryptographic Passphrase Cracking

The private key file was extracted from the target machine. Initial connection attempts failed due to the key being protected by an asymmetric passphrase. The key structure was passed to localized parsing tools to extract the cryptographic hash signature:

Bash

```
python3 /usr/share/john/ssh2john.py kay_id_rsa > kay_hash.txt  
john --wordlist=/usr/share/wordlists/rockyou.txt kay_hash.txt
```

- **Result:** **john** cracked the encryption mechanism instantly.
- **Key Passphrase:** **beeswax**

High-Privilege Account Access

Local file system configurations require strict security contexts (**0600**) before an SSH client will initialize an asymmetric handshake. The key properties were secured locally:

Bash

```
chmod 600 kay_id_rsa  
ssh -i kay_id_rsa kay@10.114.164.216
```

By authenticating with the passphrase **beeswax**, a high-privilege session was spawned natively under the **kay** identity context.

6. Post-Exploitation & Data Exfiltration

Upon upgrading to the **kay** environment profile, data exfiltration was successfully completed by reading her protected offline credential storage store:

Bash

```
cat /home/kay/pass.bak
```

The file contents revealed the final stored secrets/flags, completing total structural compromise of the user tier.

7. Remediation Strategic Matrix

1. **Restrict SMB Null Sessions:** Modify the Samba server configuration (**smb.conf**) to explicitly reject unauthenticated null sessions (**restrict anonymous = 2**). This stops attackers from scanning usernames over the network.

2. **Purge Web Development Artifacts:** Remove all cleartext developer logs, chat transcripts, or configuration notes (`.txt` files) from production web roots.
3. **Enforce SSH Key Access Policies:** Tighten home directory permissions (`chmod 700 /home/*`) across the OS environment to prevent secondary users from viewing or cloning sensitive `.ssh` assets. Ensure strong passphrases are mandatory for all generated keys.